



Government
Digital Service



Department for
Science, Innovation
& Technology

Aligning AWS log aggregation and centralised logging strategies with Secure by Design

Contents

Background	3
Purpose	3
Secure by Design on the UK Government Security website	3
1. Governance, accountability and ownership of logging	4
2. Risk-driven logging strategy and threat modelling	5
3. Architectural design of the central logging platform	6
4. Log collection, integrity and tamper resistance	6
5. Secure storage, retention and data protection	7
6. Real-time monitoring, alerting and automated response	8
7. Minimising exposure of the logging infrastructure	9
8. Continuous assurance and ongoing validation	9
9. Secure change and architectural evolution	10
10. Incident response and forensic readiness	10
More information	11

Background

In modern cloud-native environments, large volumes of logs are generated across applications, infrastructure and network services. Managing these logs in one place is essential to keep operations secure.

Logging is a key way for organisations to:

- see system activity
- check policies are being followed
- identify suspicious or malicious behavior
- help understand what happened before, during and after security incidents

For systems supporting UK Government services, it is crucial to show that logging is properly designed, implemented and governed in line with existing security requirements.

The [Secure by Design](#) approach is a government framework which embeds cyber security into digital services from the outset. Its goal is to make security an integral, proactive part of all government digital systems, rather than an afterthought.

Purpose

The purpose of this document is to help align organisations' Amazon Web Services (AWS) log aggregation and centralised logging strategies with the Secure by Design approach.

For systems hosted on AWS, this guidance recommends using cloud-native logging and monitoring services to provide a unified view of activity across applications, infrastructure and network layers.

To collect, store, analyse and protect logs in a secure and scalable manner, you can use services such as:

- [Amazon CloudWatch](#)
- [AWS CloudTrail](#)
- [Amazon S3](#)
- [Amazon OpenSearch Service](#)
- [AWS Security Hub](#)

When these services are supported by appropriate configuration standards, access controls, retention policies and monitoring processes, you can align centralised log collection and analysis with [Secure by Design principles](#).

Secure by Design on the UK Government Security website

- [Secure by Design policy](#)
- [Implementing Secure by Design](#) and [Guide to adopting Secure by Design](#)

1. Governance, accountability and ownership of logging

Defining clear accountability

Responsibility for cyber security risk must have clearly defined ownership, with the right resources and support across the organisation's governance structure.

Logging should not be treated as a vague operational duty shared between teams. It should be formally owned at the executive level, with responsibilities delegated clearly across delivery and assurance functions.

Executive ownership

The executive cyber risk owner (usually the chief information security officer (CISO) or equivalent) should:

- accept overarching accountability for the logging strategy
- have a documented mandate
- set risk-tolerance expectations

Delivery responsibilities

Operational responsibility for logging should belong to a dedicated cloud platform engineering team. This team should:

- implement, configure and maintain logging services
- have the skills and authority to configure AWS services consistently across the environment

Monitoring and response

Analysts in the Security Operations Centre (SOC) should be trained to interpret logs effectively. The SOC should be formally responsible for:

- monitoring log data
- identifying anomalies
- responding to incidents
- escalating issues when needed

Compliance

Governance, risk and compliance (GRC) teams should:

- verify that logging is complete and accurate
- check logging practices follow policy
- coordinate assurance activities
- use evidence taken directly from the centralised logging platform

Technical controls to support governance

Use [AWS Identity and Access Management \(IAM\)](#) policies to:

- separate duties
- prevent privilege escalation
- restrict configuration permissions to a limited set of roles
- require multi-factor authentication protection

Use Service Control Policies (SCPs) in [AWS Organisations](#) to prohibit actions such as:

- disabling logging services
- modifying retention policies
- deleting archived logs

These actions should only be possible through approved processes.

Supporting defence-in-depth

Together with separation of duty practices, IAM controls and SCPs also strengthen layered protection in line with Secure by Design's defence-in-depth expectations. This helps ensure that no single misconfiguration in a workload account can compromise central logging.

Supported Secure by Design principles

This approach supports the following Secure by Design principles:

- 1. Create responsibility for cyber security risk
- 8. Defend in depth
- 10. Make changes securely

2. Risk-driven logging strategy and threat modelling

Threat modelling, a key part of a risk-driven logging strategy, begins with identifying your critical assets.

Critical assets typically include:

- sensitive data stores
- privileged user accounts
- internet-facing services whose compromise would cause the most harm

The next part of threat modelling involves mapping likely threat actor capabilities and attack vectors to those assets. This highlights the specific types of events and activities that must be recorded and analysed. Refer to the Secure by Design activity [Performing threat modelling](#) for more about this.

Identify what needs to be logged

High-impact actions that attackers might target include:

- identity changes
- privilege escalations
- key management operations
- configuration modifications

These should be logged at the finest granularity available.

AWS services produce different types of logs, including:

- management events
- data events
- insights logs

Your risk-driven strategy should determine which of these categories are captured, how long they're retained and whether they need real-time analysis. This should be based on your organisation's specific risks and threat model. The security team should lead this work.

Use AWS services to provide visibility

Government organisations should enable AWS Organisations-wide API auditing through AWS CloudTrail. This captures all management plane activity across all AWS accounts and regions.

Enable [VPC Flow Logs](#) to record information about IP traffic across elastic network interfaces. This is critical for identifying unusual lateral movement or data exfiltration patterns.

Application logs should:

- use a structured format
- include correlation identifiers

A correlation identifier is a shared tracking ID that links related log entries together across systems so you can link activities with events during investigations.

Prioritise logging based on risk

Before deciding what to log, you should perform a focused risk assessment of your cloud environment. Identify:

- critical assets
- sensitive data
- privileged operations
- exposed components

Evaluate the likelihood and business impact of potential threats so you can categorise systems and events by risk level. This classification then determines:

- what should be logged
- what requires real-time monitoring
- what should be retained for longer periods

Making sure logging effort matches risk

A proportional approach helps make sure costly attention and storage resources are used to deliver the greatest security value.

This directly supports Secure by Design's requirement that controls should be informed by risk context, not applied indiscriminately.

Supported Secure by Design principles

This approach supports the following Secure by Design principles:

- 3. Adopt a risk-driven approach
- 5. Build in detect and respond security
- 7. Minimise the attack surface

3. Architectural design of the central logging platform

Architecturally, a secure AWS logging platform can benefit from:

- a logical separation of responsibilities
- a central collection point for logs
- a layered set of services that both store and analyse data without exposing it unnecessarily

In multi-account environments, set up a central logging account under an AWS Organisation. All workload accounts should forward their logs to this account, where they can be consistently:

- archived
- indexed
- analysed
- monitored

This structural separation:

- means administrators of individual workload accounts cannot disable or tamper with logs outside their scope
- supports compliance, evidence collection and audit reporting

Design a secure log-ingestion pipeline

Log ingestion typically involves routing service and application logs you've collected into:

- long-term archival storage
- optional indexing and search services for operational investigations

To reduce the attack surface and align with least-privilege network design:

- deploy services in private zones
- avoid public endpoints
- route traffic through [AWS PrivateLink](#) or [VPC Endpoints](#) wherever possible

Using private connectivity between workload accounts and central log storage:

- removes reliance on public internet connectivity
- reduces the risk of sensitive data being exposed or intercepted

Build with decoupled components

Construct the logging pipeline as a series of decoupled services linked by secure event streams and permissions. This approach:

- keeps the architecture flexible and scalable
- makes it easier for it evolve over time
- aligns with Secure by Design expectations for flexible architectures that do not require significant re-engineering

Supported Secure by Design principles

This approach supports the following Secure by Design principles:

- 6. Design flexible architectures
- 7. Minimise the attack surface
- 8. Defend in depth

For more about this, see AWS's guidance on [centralised logging and monitoring](#).

4. Log collection, integrity and tamper resistance

Collect logs comprehensively

Logs must be collected in a way that ensures both completeness and integrity.

You should enable organisation-wide trails using AWS CloudTrail with multi-region support to capture management and data events wherever they occur. By integrating CloudTrail with [CloudWatch Logs](#) you can generate metrics and alarms based on activity patterns. Delivering these log files to Amazon S3 provides long-term storage.

Protect logs from tampering

CloudTrail includes a log file integrity validation feature which uses cryptographic hashes to detect tampering. When this feature is enabled on your CloudTrail trails, you can detect and respond to:

- authorised or unauthorised modification of log files
- tampering of log files in transit or at rest

This reduces the risk of silent deletion or audit evidence being manipulated.

Collect network and application logs

Network logs from Elastic Load Balancers (ELBs), VPC Flow Logs and similar sources should be forwarded into CloudWatch Log Groups and then delivered to your central S3 bucket using Firehose.

Firehose can be configured with server-side encryption and retry policies so that delivery is resilient and secure.

Application logs emitted by workloads should use structured JSON formats that include:

- timestamps
- request and correlation identifiers
- user or service identities
- execution context

Structured logs are easier to filter, search and analyse downstream in investigation workflows.

Secure logs at rest

Server-side encryption with [AWS Key Management Service \(KMS\)](#) should be mandatory for all logs at rest. To reduce the risk of key misuse or accidental disclosure:

- centralise key policies
- restrict key administration to the security team

Use S3 object versioning to prevent accidental overwrites and S3 Object Lock in compliance mode to prevent deletion for a defined retention period. These controls further strengthen tamper resistance.

Ensure end-to-end integrity

Combining cryptographic integrity checks, secure delivery pipelines and immutability controls helps your logging strategy meet Secure by Design expectations around both detection capability and data integrity.

Supported Secure by Design principles

This approach supports the following Secure by Design principles:

- 5. Build in detect and respond security
- 8. Defend in depth
- 10. Make changes securely

5. Secure storage, retention and data protection

Set retention based on risk and business need

You should base log retention policies on:

- business impact assessments
- regulatory requirements
- forensic readiness objectives

Multi-year retention is often appropriate to support:

- audit trails involving API activity or privileged identity changes
- investigations that may span long periods

Conversely, high-volume application debug logs can usually be kept for shorter periods unless they contain data relevant to security investigations.

Use S3 Lifecycle policies and cost-efficient storage

In AWS, S3 Lifecycle policies can be configured to automatically:

- transition older log objects to cost-efficient storage classes (for example, [S3 Glacier](#) or Glacier Deep Archive)
- preserve immutability requirements for the period defined by your policy

All storage must be encrypted using AWS KMS keys that you manage. You should only grant access to those keys to authorised roles.

Access to the logs themselves should also be controlled at the bucket policy and IAM policy level. This is so only roles with a legitimate operational need can read or export sensitive information.

Protect personal and sensitive data

Data protection is not only about encryption. Logs can contain sensitive personal data, so organisations should:

- configure logs to avoid capturing unnecessary personal data
- use pseudonymisation or hashing if capturing personal data is unavoidable

This reduces the exposure surface in the event of a breach and aligns with Secure by Design's emphasis on proportionate controls that respect privacy while still being useful in investigations.

For more about this, see the Information Commissioner's Office (ICO) guidance on [encryption and data protection](#).

Supported Secure by Design principles

This approach supports the following Secure by Design principles:

- 1. Create responsibility for cyber security risk
- 3. Adopt a risk-driven approach
- 8. Defend in depth

6. Real-time monitoring, alerting and automated response

Build real-time monitoring into the logging pipeline

Real-time monitoring and alerting must be an integral part of the logging pipeline.

Use metric filters in [CloudWatch Logs](#) to detect important patterns such as:

- use of the root account
- creation or deletion of IAM policies
- attempts to stop or disable logging services

Detected events can be routed through [Amazon EventBridge](#) and delivered to:

- notification channels such as [Amazon Simple Notification Service \(SNS\)](#)
- downstream incident management systems such as ServiceNow

Integrate AWS threat-detection services

You can strengthen detection capability further by integrating findings from security services such as:

- [Amazon GuardDuty](#), which conducts continuous threat detection using machine learning and anomaly detection
- [AWS Security Hub](#), which aggregates security alerts and findings across accounts and across the organisational

When these services identify suspicious activity, you can forward those findings to your central logging account. You can then correlate them with other telemetry to reduce false positives and improve investigative context.

Use automated remediation where appropriate

Where your organisation's policy allows, you can trigger automated remediation in response to specific detections. For example, an unauthorised attempt to modify a security group rule could trigger an [AWS Lambda](#) function to:

- revert the change
- log the activity for audit purposes

By building detection and response into your logging architecture and integrating it with event-driven workflows, you:

- satisfy Secure by Design's requirement for systems that can detect and respond securely
- support ongoing assurance by making these capabilities measurable and repeatable

Supported Secure by Design principles

This approach supports the following Secure by Design principles:

- 4. Design usable security controls
- 5. Build in detect and respond security
- 9. Embed continuous assurance

7. Minimising exposure of the logging infrastructure

Restrict and harden access to the logging environment

The central logging platform should be a hardened environment with minimal exposure to potential attackers.

Access to the central logging account should:

- require strong identity verification through your enterprise identity provider
- enforce multi-factor authentication (MFA) for all administrative actions
- only allow console access authorised personnel
- be fully audited through session logging

Deploy services privately and avoid public endpoints

Indexing and search services such as Amazon OpenSearch Service should be deployed:

- in private subnets
- without public endpoints
- with access controlled by security group policies that permit traffic only from known sources, such as your security tooling accounts

Network routes should rely on:

- [AWS PrivateLink](#)
- [VPC endpoints](#)

This avoids sending traffic over the public internet, reducing the risk of interception or exposing sensitive log data.

Using Service Control Policies

Use Service Control Policies (SCPs) to prevent disabling or modifying critical logging components. SCPs can deny attempts to:

- stop CloudTrail trails
- delete log buckets
- alter retention periods except through approved change channels

Reduce attack surface through layer controls

By constraining network exposure, limiting permissions, putting in place preventive controls and detective monitoring, the logging infrastructure becomes a secure service, with a reduced attack surface. This approach aligns with Secure by Design's expectations for layered protection.

Supported Secure by Design principles

This approach supports the following Secure by Design principles:

- 1. Create responsibility for cyber security risk
- 7. Minimise the attack surface
- 8. Defend in depth

8. Continuous assurance and ongoing validation

Validate controls regularly

Do not deploy controls once and assume they will remain effective. Continuous assurance means you must validate them throughout the system's life cycle. Secure by Design requires assurance activities that:

- operate throughout the system life cycle
- show that controls remain correctly configured and operational

Use AWS services for configuration checks

In AWS, continuous validation can be achieved through services such as [AWS Config](#). This assesses your resource configurations against defined rules. For example, Config rules can check that:

- CloudTrail is enabled in all regions
- S3 buckets containing logs are encrypted
- log retention settings comply with your organisation's policy

Monitor the health and performance of the logging platform

Dashboards help teams monitor the operational health of the logging platform. They should provide insights into:

- log coverage
- ingestion latency
- detection event rates
- alert statuses

Where there are deviations, automated notifications should be triggered and investigated promptly.

Retain evidence

Evidence collected from these assurance activities should itself be logged and retained. This allows your organisation to carry out periodic audit reviews and demonstrate compliance and control effectiveness over time.

Supported Secure by Design principles

This approach supports the following Secure by Design principles:

- 1. Create responsibility for cyber security risk
- 9. Embed continuous assurance
- 10. Make changes securely

9. Secure change and architectural evolution

Build the platform so it can evolve safely

Cloud environments and threat landscapes evolve continually. Your logging architecture must be designed to adapt securely without introducing new vulnerabilities.

For the logging platform, this means defining all infrastructure in code using tools such as:

- [AWS CloudFormation](#)
- [AWS Cloud Development Kit \(CDK\)](#)

Deploy changes through a controlled Continuous Integration and Continuous Delivery or Deployment (CI/CD) pipeline that includes automated policy analysis and testing in non-production environments.

Apply controlled and reviewable changes

Changes to key components, such as log collection rules, retention policies or alert definitions, should be:

- peer reviewed
- approved by security teams
- validated through pipeline gates

Pipeline gates should enforce syntax validation and simulate deployments before they reach production. Version control should ensure that every change is accountable and that rollbacks are possible if there are unintended consequences.

Use modular and decoupled services

So it's easier to incorporate new log sources or modify existing ones without revisiting the entire architecture, you can use modular, decoupled services such as:

- [Amazon Kinesis Data Streams](#) for streaming
- [Amazon EventBridge](#) for routing

Supported Secure by Design principles

By operationalising secure change practices, you help ensure the logging platform continues to:

- remain flexible
- provide reliable evidence
- support continuous assurance activities

This approach supports the following Secure by Design principles:

- 6. Design flexible architectures
- 9. Embed continuous assurance
- 10. Make changes securely

10. Incident response and forensic readiness

Make sure the platform supports investigations

The main purpose of a centralised logging platform is to support incident response and forensic analysis. Forensic readiness means that logs are generated with enough context to allow investigators to reconstruct the sequence of events clearly and confidently.

Each log entry should include:

- identity information
- accurate timestamps
- relevant contextual data

Link related events across systems

Centralised logs should be indexed with correlation identifiers. This is so investigators can link:

- application-level events
- [control plane](#) activity
- network-level events

Preserve integrity and chain of custody

Archived logs must be retrievable in a controlled way that:

- preserves chain of custody
- demonstrates integrity from the point of collection through to analysis

Access to forensic data should be strictly controlled and logged.

Prepare playbooks and runbooks

Playbooks and runbooks should be developed and rehearsed so that incident responders have well-defined procedures for:

- extracting relevant log data
- preserving it securely
- interpreting it

For further detail, please refer to principle D1 of the Government Cyber Security Policy Handbook, [Response and Recovery Planning](#).

Embed forensic readiness into the platform

Embedding forensic readiness into your logging strategy, ensures you:

- align with Secure by Design expectations for detection, response and recovery
- fulfil organisational needs for evidential quality

Supported Secure by Design principles

This approach supports the following Secure by Design principles:

- 1. Create responsibility for cyber security risk
- 5. Build in detect and respond security
- 8. Defend in depth

More information

- [Secure by Design Principles \(UK Government Security\)](#)
- [Secure by Design Activities \(UK Government Security\)](#)
- [Logging and protective monitoring \(NCSC\)](#)
- [Introduction to logging for security purposes \(NCSC\)](#)
- [Threat modelling \(NCSC\)](#)
- [Managing observability \(UK Government Security\)](#)
- [Encryption and data protection \(ICO\)](#)